

Cybersecurity Capstone Report

Consolidated Security Assessment, Risk Register & Incident-Response Procedure

Program: Skill Set Go EduTech — Cybersecurity Internship (Week 4 Capstone)

Date: October 2026

Prepared by: Muhammad Usman

Classification: Internal Training / Legal Practice-Environment Assessment

1. Executive Summary

This capstone report consolidates four weeks of hands-on security work performed during the Skill Set Go Cybersecurity Internship into a single, formal security deliverable. It draws on practical testing against two deliberately vulnerable web applications (OWASP Juice Shop and DVWA) and a personal SOC home lab (Splunk/Sysmon monitoring of simulated attack techniques), producing a structured assessment, a formal risk register with recommended controls, and an incident-response procedure grounded in real captured evidence.

Six vulnerabilities were identified and validated across the two applications, four of which fall under the Injection category despite testing entirely independent codebases — indicating a systemic rather than isolated weakness pattern. Separately, the SOC home lab evidenced one fully-documented attack-to-detection chain (encoded PowerShell execution) alongside a transparently-recorded evidence gap for two other simulated techniques, which directly informed this report's incident-response procedure.

Key Figures

Metric	Value
Applications assessed	2 (OWASP Juice Shop, DVWA)
Vulnerabilities identified	6
Critical-severity findings	1
High-severity findings	4
Medium-severity findings	1
Fully evidenced SOC detections	1 of 3 simulated techniques

2. Scope & Methodology

2.1 Scope

Targets: OWASP Juice Shop (Week 1), DVWA (Week 2), personal SOC home lab — Kali attacker VM against a Windows 10 target with Splunk/Sysmon monitoring (Week 3). **Environment:** all testing performed in local, legal, isolated lab environments (Docker containers, VirtualBox VMs). **Out of scope:** any production system; denial-of-service testing.

2.2 Methodology

- **Reconnaissance** — identify each target's technology stack and available attack surface.
- **Manual testing** — craft and submit payloads to test input handling, authentication, and session logic.
- **Source code review** — where available, confirm root cause directly rather than inferring from behavior alone.
- **Log-based detection testing** — simulate attack techniques against a monitored host and evaluate whether telemetry captured the activity.
- **Risk rating and control mapping** — rate each finding by likelihood and impact, and map recommended controls.

3. Consolidated Security Assessment Findings

Full technical detail for each finding is preserved in its original week's documentation (week1/, week2/ folders). This section presents the consolidated view.

#	Finding	Target	OWASP 2025	Severity
1	SQL Injection (search endpoint)	Juice Shop	A05 Injection	High
2	Missing CSP header	Juice Shop	A02 Misconfig.	Medium
3	DOM-based XSS (search field)	Juice Shop	A05 Injection	High
4	SQL Injection (User ID lookup)	DVWA	A05 Injection	High
5	OS Command Injection (ping)	DVWA	A05 Injection	Critical
6	Predictable Session IDs	DVWA	A07 / A04	High

Pattern observed: 4 of 6 findings are Injection-class across two unrelated codebases, suggesting input validation is a systemic rather than isolated weakness. The two non-injection findings (Missing CSP, Predictable Session IDs) both represent absent defense-in-depth rather than direct exploit paths — neither grants access alone, but each removes a safety net that would otherwise have limited the

impact of the injection findings.

4. Risk Register & Recommended Controls

Risk ID	Description	Likelihood	Impact	Rating
RISK-01	SQL Injection — Juice Shop	High	High	High
RISK-02	Missing CSP header	High	Medium	Medium
RISK-03	DOM-based XSS	High	High	High
RISK-04	SQL Injection — DVWA	High	High	High
RISK-05	OS Command Injection	High	Critical	Critical
RISK-06	Predictable Session IDs	High	High	High

Every risk in this register carries a High Likelihood rating, because each finding was successfully and repeatably exploited during testing with no rate-limiting, WAF, or detection control observed in any target. This uniformity is itself a governance-level finding: the absence of any layered defense, independent of which specific vulnerability is considered.

4.1 Recommended Control Priorities

Priority	Control	Addresses
1	Parameterized queries / ORM for all DB access	RISK-01, RISK-04
2	Eliminate shell command construction from user input	RISK-05
3	Cryptographically secure session token generation	RISK-06
4	Output encoding/sanitization for rendered user input	RISK-03
5	Content-Security-Policy header	RISK-02, RISK-03
6	Centralized logging/alerting on injection-pattern requests	All

5. Incident-Response Procedure Summary

A full incident-response procedure was developed around the internship's one fully-evidenced SOC detection: an encoded PowerShell execution technique (MITRE ATT&CK T1059.001, T1027), identified via a Sysmon FileCreate event showing a `__PSScriptPolicyTest_*.ps1` temp file artifact.

Stage	Key Action
1. Preparation	Sysmon deployed with process/file-creation logging, forwarded to Splunk; saved detection searches
2. Identification	Correlate FileCreate event by ProcessGuid; decode any Base64 command found
3. Containment	Isolate host from network; suspend affected user account
4. Eradication	Terminate malicious process; remove dropped files and persistence mechanisms
5. Recovery	Re-enable host/account after verification; heightened monitoring for 72 hours
6. Lessons Learned	Identify whether detection was timely; recommend script block logging going forward

This procedure's Preparation stage was directly shaped by a gap identified in Week 3: two of three simulated attack techniques (network reconnaissance, SMB brute-force) lacked a corresponding saved detection query, while the PowerShell technique succeeded because a targeted search had been run and captured at the time. The procedure above treats pre-built, saved detection searches as a Preparation-stage requirement specifically to close that gap for future incidents.

6. Conclusion

Across four weeks, this internship produced a validated security assessment spanning two independent applications, a formal risk register with prioritized controls, and an incident-response procedure grounded in real captured telemetry rather than a generic template. The most significant cross-cutting finding is not any single vulnerability, but the consistent absence of layered defenses — no application tested had any control in place that would have slowed, contained, or alerted on the identified attacks. Remediation should therefore prioritize not just fixing individual bugs, but establishing baseline preventive and detective controls (parameterized queries, CSP, secure session handling, and centralized alerting) as standard practice across any future development.

This capstone report, together with the supporting evidence and documentation across weeks 1 through 4, represents the complete deliverable for the Skill Set Go Cybersecurity Internship's 4-week practical track.